

ADVISORIES

Security Advisories — Risk-Accepted Findings

Field	Value
Status	active
Scope	Operator-visible record of accepted, unremediated security findings for HelixCluster
Source	make security-scan (govulncheck + gosec + trivy), see SECURITY_SCANNING.md

This document records security findings that have been **reviewed and risk-accepted** because no upstream fix is available, alongside the mitigation/monitoring posture for each. It is the honest sink-side counterpart to the scan-only make security-scan target: scanning captures findings, this document records the disposition.

A finding listed here is **not** “ignored” — it is tracked, justified, and re-checked each time the security scan is re-run, so it can be remediated the moment an upstream fix lands.

GO-2024-3218 — libp2p Kademlia DHT censorship (no upstream fix)

Field	Value
Advisory ID	G0-2024-3218 (Go vulnerability database)
Component	github.com/libp2p/go-libp2p-kad-dht
Affected version	v0.40.0 (currently pinned)
Class	Availability / censorship (DHT record/peer-routing manipulation)
Severity	

Field	Value
	Moderate — availability impact only; not RCE, not authn/authz bypass, not data disclosure
Detector	govulncheck (reachability-aware)
Upstream fix	None available — no fixed version published at time of acceptance
Disposition	Risk-accepted with mitigations (see below)

Affected modules and call paths

The vulnerable package is reachable (not merely present) from two modules, both of which build a libp2p host with a Kademlia DHT for peer discovery:

Module	go.mod entry	Reachable call path
discovery/p2p	discovery/p2p/go.mod	discovery/p2p/ node.go → dht.New(ctx, h, dht.Mode(...)) (node.go:125); DHT default mode ModeServer
clusternode	clusternode/go.mod (transitive, // indirect)	cluster node agent libp2p host wiring (clusternode/ cluster.go, clusternode/ nodeagent.go)

govulncheck flags the symbols as **actually reachable** from these entry points, so this is a genuine reachable finding rather than a present-but-dead dependency.

Why this severity (and why it is acceptable)

G0-2024-3218 is a **DHT-censorship / availability** class issue: a malicious peer participating in the same Kademlia DHT can influence peer-routing / record lookups, degrading or censoring discovery results. It does **not** grant code execution, does **not** bypass authentication or authorization, and does **not** disclose data. HelixCluster's trust and authorization decisions do not rely on DHT lookups being tamper-proof — the DHT is a discovery convenience, and authenticated mTLS / Raft / etcd remain the source of truth for cluster state and membership. The blast radius is therefore limited to discovery availability/latency, not integrity or confidentiality of the control plane.

Mitigation and monitoring guidance

Because no upstream fix exists, the finding is accepted with the following standing mitigations:

1. **Monitor for an upstream patch.** Re-run `make security-scan` on the regular cadence; the moment `go-libp2p-kad-dht` publishes a fixed release, bump the pin in `discovery/p2p/go.mod` and `clusternode/go.mod` and remove this acceptance.
 2. **DHT peer hygiene at the network layer.** Restrict DHT participation to trusted network segments where practical; do not expose the discovery DHT to the open public internet for production fleets. Prefer the config-driven persistent-worker deploy path (operator-controlled inventory) over open public DHT bootstrap for production membership.
 3. **Do not treat DHT results as authoritative.** Cluster membership and trust continue to be anchored in authenticated channels (mTLS, etcd, Raft), so a censored/poisoned DHT result cannot escalate beyond degraded discovery.
 4. **Defense in depth.** Keep gossip/SWIM and etcd-backed registration as the resilient fallback for node discovery if DHT routing is degraded.
-

trivy “secrets” — confirmed test-sentinel false positives (allowlisted)

trivy reports 4 “secret” hits. All 4 are **confirmed false positives**: they are placeholder / sentinel tokens used inside tests and QA transcripts (e.g. `*-must-not-leak-*` style strings that *assert* secrets do **not** leak). They are not real credentials, carry no access, and are intentionally present to drive negative tests. They are allowlisted and require no remediation. See the triage note in [SECURITY_SCANNING.md](#) (“trivy secrets: verify each hit — placeholder/sentinel tokens used in tests and QA transcripts ... are false positives”).

Re-validation

These dispositions are re-checked on every `make security-scan` run. Captured scan evidence lands under `qa-results/security/<run-id>/`. Any change in upstream fix availability for G0-2024-3218 must trigger remediation (dependency bump) and removal of the corresponding acceptance entry above, per the project’s no-stale-docs guarantee.